

Retire.js Scan Evidence (Vulnerable & Outdated Components)

MEDIUM Target: OWASP/bWAPP (Buggy Web Application) — Lab IT Audit

1. Informasi Pengujian

Tanggal Pengujian	17 Juni 2026
Tool	Retire.js v5.4.3 (scanner komponen JavaScript usang)
Metode	Unduh seluruh file JavaScript yang disajikan target, lalu pindai dengan signature Retire.js (database OSV/GitHub Advisory)
Target	<code>http://localhost:8080/js/</code>
Komponen Diuji	<code>jquery-1.4.4.min.js</code> , <code>json2.js</code> , <code>html5.js</code> , <code>xss_ajax_1.js</code>
Security Level	Low (security_level=0)

2. Metodologi

Retire.js memindai berkas JavaScript lokal dan mencocokkan sidik (hash/regex konten) dengan basis data kerentanan komponen. Karena bWAPP tidak menggunakan manajer paket (npm/Composer) untuk aset front-end-nya, berkas JS yang disajikan server diunduh lebih dulu, lalu folder hasil unduhan dipindai. Perintah lengkap untuk reproduksi tersedia di `doc/retire_output/command.txt`.

```
WORK=$(mktemp -d)

for f in jquery-1.4.4.min.js json2.js html5.js xss_ajax_1.js; do

    curl -s -o "$WORK/$f" "http://localhost:8080/js/$f"

done
```

```
npx retire --path "$WORK" --outputformat json > retire_result.json
```

3. Ringkasan Temuan

Berkas	Komponen		Status
jquery-1.4.4.min.js	jQuery	1.4.4 (2010)	7 kerentanan
json2.js	json2	-	Bersih
html5.js	html5shiv	-	Bersih
xss_ajax_1.js	(skrip bawaan bWAPP)	-	Bersih

4. Detail Kerentanan: jQuery 1.4.4

jQuery 1.4.4 dirilis tahun 2010 dan sudah **End-of-Life**. Retire.js mencocokkannya dengan 7 entri kerentanan berikut:

Severitas	CVE / Identitas	Ringkasan
Medium	CVE-2011-4969	XSS melalui <code>location.hash</code>
Medium	CVE-2012-6708	Selector ditafsirkan sebagai HTML, memungkinkan XSS

M
ed
iu
m

CVE-20
20-7656 Method `.load()` gagal menyaring tag `</script >` berisi spasi, sehingga script tereksekusi

M
ed
iu
m

CVE-20
15-9251 Permintaan CORS pihak ketiga dapat tereksekusi (potensi XSS)

M
ed
iu
m

CVE-20
19-
11358 Prototype pollution pada `jQuery.extend(true, {}, ...)`

M
ed
iu
m

CVE-20
20-
11023 HTML berisi elemen `<option>` tak tepercaya dapat mengeksekusi kode meski sudah disanitasi

Lo
w

EOL
(retid
73) jQuery 1.x/2.x tidak lagi menerima pembaruan keamanan

Arsip mentah hasil scan: `doc/retire_output/retire_result.json`.

5. Penilaian Risiko

Aspek

Keterangan

Severity

MEDIUM

OWASP
Top 10
2021

A06:2021 Vulnerable and Outdated Components

Root
Cause

Penggunaan pustaka pihak ketiga (jQuery 1.4.4) yang sudah usang dan tidak pernah diperbarui

Impact

Mayoritas kerentanan bersifat XSS dan prototype pollution, memperbesar permukaan serangan client-side yang sudah ada pada BWAPP

Keterkaita
n Temuan

Memperkuat temuan XSS (lihat `xss_scan`) dari sisi komponen. Direktori `/js/` juga dapat di-*listing* (A05 Security Misconfiguration), memudahkan penyerang

6. Rekomendasi Remediasi

1. **Perbarui jQuery** ke versi terkini yang didukung (minimal 3.5.0+ yang sudah menambal CVE-2020-11022/11023).
2. Terapkan proses **inventarisasi dan pemantauan komponen** (Software Composition Analysis) secara berkala, mis. Retire.js atau OWASP Dependency-Check di pipeline.
3. Hapus pustaka yang tidak terpakai dan **nonaktifkan directory listing** pada folder aset (Options -Indexes di Apache).
4. Pasang **Content Security Policy (CSP)** sebagai mitigasi berlapis terhadap eksploitasi XSS pada pustaka usang.